

ACTIRA

Agentic Cybersecurity Threat Intelligence & Incident Response Advisor

STATUS	Final Capstone Project submission pack
PROGRAM	TalentSprint / IISc track
MATURITY	Enterprise Pilot Ready (single-tenant)
BOARD SCORE	78 / 100
GOLDEN IR	37 cases IoC F1 0.982 Technique recall 0.930
TEST PACK	66 automated tests passed (2026-07-27)
COVERAGE	Architecture A-E, UI 01-18, demo video + voiceover
DATE	27 July 2026

Final Capstone Project deliverable. Advisory AI with Human-in-the-Loop gates. Does not replace SIEM/XDR platforms of record (Sentinel, Splunk ES, Falcon, XSIAM). Compliance scores are product alignment only - not formal certification. Appendix E lists roles for completeness only - product capabilities are the evaluation focus.



Table of contents

1. Introduction
 2. Literature & related work
 3. System requirements
 4. System architecture
 5. Design & methodology
 6. Implementation
 7. Testing & evaluation
 8. Results & discussion
 9. Challenges & mitigations
 10. Conclusion & future work
- Architecture detail (poster + control tables)
- Figures - Screenshots & architecture (light theme)
- References
- A. Appendix A - Test case catalog (detailed)
 - B. Appendix B - API surface (detailed)
 - C. Appendix C - Sample outputs
 - D. Appendix D - Configuration
 - E. Appendix E - Team roles
 - F. Appendix F - Glossary

Abstract

ACTIRA is an AI-assisted Security Operations platform that automates multi-format log ingestion, Indicator of Compromise (IoC) extraction, threat-intelligence enrichment, MITRE ATT&CK mapping, hybrid Retrieval-Augmented Generation (RAG), and citation-grounded incident response (IR) playbook generation, with mandatory Human-in-the-Loop (HiTL) review for high-risk cases. The system is implemented as a modular FastAPI and React application backed by MongoDB and LanceDB, with multi-provider LLM support, cross-provider fallbacks, offline golden evaluation, and enterprise-oriented controls (RBAC, secrets vault, audit trail with integrity hashing, compliance alignment scoring).

Offline golden IR evaluation on 37 cases yields mean IoC F1 ~ 0.98, mean technique recall ~ 0.93, full NIST-style playbook phase coverage, and zero case errors under template playbooks-providing a reproducible CI gate independent of live LLM APIs. The product exceeds a thin Gradio demo: investigation workspace, review queue, hunt, analytics, compliance evidence packs, and Docker/Kubernetes packaging support a single-tenant enterprise pilot narrative. Limitations include single-tenant deployment, heuristic ATT&CK mapping, dependence on external LLM/TI APIs for peak quality, and no claim to replace SIEM/XDR platforms of record (Sentinel, Splunk ES, Falcon, XSIAM).

Keywords: Agentic AI, RAG, MITRE ATT&CK, Human-in-the-Loop, SOC, Incident Response, LanceDB, FastAPI

Chapter 1 - Introduction

1.1 Background

Security Operations Centers (SOCs) face sustained growth in alert volume from SIEM, EDR, cloud, and network sensors. Analysts must extract IoCs, enrich them with threat intelligence (TI), map activity to MITRE ATT&CK, and produce actionable IR playbooks-often under time pressure and with inconsistent documentation. General-purpose LLM chatbots reduce typing but introduce hallucination, missing audit trails, and no formal human gate for high-risk actions.

1.2 Problem statement

Manual pipelines for parse -> IoC -> TI -> ATT&CK -> playbook are slow, non-reproducible, and poorly grounded in organizational knowledge bases. Commercial SOAR platforms are powerful but heavy, closed, and expensive for education and mid-market pilots. Capstone Project 4 asks for an agentic cybersecurity threat intelligence and IR advisor that closes this gap with open, explainable AI and human oversight.

1.3 Objectives

ID	Objective
O1	Multi-format log ingest and structured event normalization
O2	Automated IoC extraction and TI enrichment (live or mock)
O3	MITRE ATT&CK technique mapping and visualization
O4	Hybrid RAG over IR knowledge with citation-grounded playbooks
O5	HiTL review for critical severity / low-grounding cases
O6	Investigation workspace as system of record for a case
O7	Offline golden evaluation and RBAC-hardened API
O8	Deployable stack (Compose / Kubernetes) with ops docs

Non-functional: pilot-class latency, secret hygiene, auditability, honest data defaults (no silent demo KPI fill).

1.4 Scope and non-goals

In scope: single-tenant SOC console for upload-driven IR advising, workspace investigation, review, compliance alignment, multi-provider LLM.

Out of scope (explicit non-goals):

- Replacement for Microsoft Sentinel, Splunk ES, CrowdStrike Falcon, Cortex XSIAM, or Google SecOps as SIEM/XDR of record

- Multi-tenant SaaS isolation (v1)
- Unsupervised SOAR execution / auto-remediation without human gate
- Formal ISO/SOC2 certification (alignment score only)

1.5 Contributions

- End-to-end modular IR pipeline with job queue and multi-format parsers
- Hybrid BM25 + LanceDB vector retrieval with citation allow-listing
- Investigation workspace (timeline, graph, notes, RCA, playbooks)
- HiTL policy gates + review queue with audit
- Offline golden IR suite (CI-gated metrics)
- Wave C: compliance alignment score, audit integrity chain, executive export
- Multi-provider LLM catalog (free/paid) with cross-provider fallback
- React enterprise UI exceeding Gradio/Streamlit baseline of the capstone brief

1.6 Report organization

Chapters 2-3 establish context and requirements; 4-6 describe architecture, design, and implementation; 7-8 present evaluation and results; 9-10 cover challenges and future work. Appendices index tests, APIs, and configuration.

Chapter 2 - Literature & related work

2.1 RAG for knowledge-intensive tasks

Lewis et al. (2020) introduced Retrieval-Augmented Generation, combining parametric LLMs with non-parametric memory. ACTIRA applies hybrid lexical + dense retrieval (Reciprocal Rank Fusion) over IR playbook knowledge and enforces citation IDs within a known allow-list to reduce ungrounded advice.

2.2 MITRE ATT&CK and IR standards

MITRE ATT&CK provides a shared taxonomy of adversary techniques. NIST SP 800-61 structures incident handling (preparation, detection, containment, eradication, recovery, lessons learned). ACTIRA maps techniques heuristically from evidence and generates playbooks with NIST-style phases; timeline and RCA support kill-chain narrative without claiming full STIX/TAXII enterprise sync.

2.3 Agentic systems

Industry frameworks (LangGraph, CrewAI, AutoGen) emphasize multi-agent orchestration. ACTIRA implements a modular agentic pipeline-named stages (parse, enrich, map, retrieve, generate, gate)-rather than a full multi-agent swarm product. This choice prioritizes determinism, offline eval, and operational simplicity for pilot demos while remaining honest about "agentic" scope.

2.4 Commercial SOC platforms

Enterprise platforms excel at data lakes, connectors, and SOAR execution. ACTIRA does not compete on ingest scale; it competes on grounded IR narrative, HiTL, investigation workspace, and reproducible offline evaluation-complementary to SIEM dual-run pilots.

2.5 Research / product gap

Open stacks rarely combine (a) multi-format evidence -> (b) hybrid RAG playbooks with citations -> (c) mandatory HiTL -> (d) workspace UX -> (e) CI golden gates in one deployable package. ACTIRA targets that gap for education and single-tenant pilots.

Chapter 3 - System requirements

3.1 Personas

Persona	Needs	Primary surfaces
SOC Analyst	Fast triage, structured IR	Upload, Incidents, Workspace, Hunt
Senior Reviewer	Controlled approval	Review Queue, Audit
Admin	Keys, thresholds, health	Settings, Ops, Golden Benchmark
Executive (demo)	Risk snapshot	Dashboard, Compliance, Export

3.2 Functional requirements (summary)

FR	Description	Status
FR-1	Parse Apache/Nginx/Syslog/Windows + extended formats	Done
FR-2	Extract IP/domain/URL/hash IoCs	Done
FR-3	Enrich via AbuseIPDB/VT (mock without keys)	Done
FR-4	Map MITRE ATT&CK techniques	Done (heuristic)
FR-5	Hybrid RAG IR playbooks	Done
FR-6	HiTL for critical / low grounding	Done
FR-7	Dashboard KPIs & ATT&CK heatmap	Done (live default)
FR-8	Investigation workspace tabs	Done
FR-9	Auth + RBAC	Done
FR-10	Compliance alignment + audit integrity	Done (Wave C)

3.3 Non-functional requirements

NFR	Target	Approach
Security	Role isolation, vault, lockout	Cookie sessions, RBAC matrix tests
Auditability	Who/what/when + integrity	SHA-256 audit chain
Latency	Pilot-class, demo <10 min golden path	Job queue, KPI cache
Honesty	No silent fake dashboard data	Demo fallback opt-in only
Deployability	Compose + Helm	deployments/

3.4 Success metrics

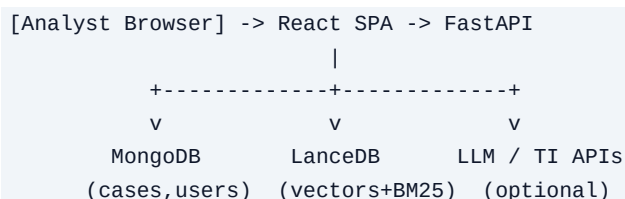
Metric	Target	Observed (2026-07-26)
Golden cases	>= 30	37
Mean IoC F1	>= 0.85	0.982
Mean technique recall	>= 0.80	0.930
Mean grounding	>= 0.50	1.0 (template path)
Full phase coverage	100%	1.0
Mean offline latency	<= 7 s	< 0.01 s
CI gate failures	0	0
Enterprise board score	Pilot	78/100

Chapter 4 - System architecture

4.1 Architecture style

ACTIRA is a modular monolith (ADR 0001): one backend process with clear router/service boundaries, dual API mounts (/api and /api/v1), and a React SPA. This optimizes demo reliability and single-tenant ops over premature microservices.

4.2 High-level context



4.3 Data flow

- Upload multi-file/ZIP evidence -> job enqueued
- Pipeline parse -> CES events -> IoC extract -> enrich -> ATT&CK -> RAG -> playbook
- HiTL gate may force pending_review
- UI Dashboard/Incidents/Workspace/Review consume REST (+ SSE for investigator)
- Audit/Compliance record actions; executive export packages evidence

4.4 Component view

Layer	Responsibilities
Frontend	Auth, pages, design system, HelpTips
API routers	Auth, incidents, upload, review, hunt, settings, compliance, audit, eval
Services	Analytics KPIs, pipeline orchestration, LLM provider, vault
Engines	Parsers, IoC, enrichment, attack mapping, hybrid RAG, playbook agent, HiTL
Data	MongoDB documents; LanceDB hybrid index; optional file evidence

4.5 AI workflow

Hybrid retrieval (BM25 + dense, RRF, optional re-rank) feeds structured playbook generation. Grounding score and citation IDs constrain outputs. Multi-provider LLM layer selects free/paid models and falls back across providers; template playbooks ensure offline continuity.

4.6 Security architecture

- Password login with logout; JWT session cookies
- RBAC: analyst / senior_reviewer / admin
- Secrets vault (encrypt-at-rest; never return raw keys)
- ZIP bomb / size limits on ingest
- Audit trail with integrity hashing
- Compliance alignment score (not certification)

4.7 Deployment

Docker Compose for lab; Kubernetes/Helm charts under deployments/. Environment via .env and Settings UI vault. CI: GitHub Actions for tests and golden gates.

Chapter 5 - Design & methodology

5.1 Datasets and knowledge bases

- Synthetic multi-format logs under samples/
- Golden IR dataset (backend/tests/golden/dataset.json, 37 cases)
- MITRE-oriented technique catalog and IR playbook KB in LanceDB
- Optional CVE/KEV enrichment when configured

5.2 Log analysis pipeline

Parsers normalize heterogeneous sources (Apache, Nginx, Syslog, Windows-oriented formats, Suricata, Zeek, Sysmon, Defender). Correlated events form Common Event Schema (CES) records feeding IoC and technique inference. Pipeline isolation ensures one bad file does not abort the batch.

5.3 IoC extraction and TI enrichment

Regex/heuristics extract IPs, domains, URLs, hashes. Private IPs are filtered from public enrichment. Without API keys, enrichment returns mock results for offline demos; with keys, AbuseIPDB, VirusTotal, and additional providers apply. FORCE MOCK_TI forces deterministic mock mode for tests.

5.4 ATT&CK mapping

Keyword and pattern heuristics map evidence to technique IDs (e.g., brute-force -> T1110-class). Optional LLM refine can improve narrative; heatmaps and incident filters expose technique prevalence. Mapping is not a full enterprise ATT&CK engine.

5.5 Hybrid RAG

Lexical BM25 + LanceDB vectors fused by RRF; optional Cohere re-rank. Design choice of LanceDB over Chroma is documented (ADR 0002) for hybrid search ergonomics. Retrieval pairs support offline Hit@k style checks.

5.6 Playbook generation

Prompts request structured JSON with containment, eradication, recovery, and lessons-learned phases. Outputs parse through resilient parse_llm_json (fences, trailing commas). Citations must subset the KB allow-list; low grounding triggers HiTL.

5.7 HiTL policy

Critical severity and low grounding force review. Reviewers approve/reject with comments; race conditions yield 409. Audit records decisions.

5.8 Investigation workspace

Single case screen: Case, Evidence, Timeline, Graph/Assets/Users, TI, MITRE, Notes, Playbooks, RCA, AI investigator stream. URL tab state supports shareable deep links.

5.9 LLM multi-provider and fallback

Settings catalog lists free and paid models across providers. Soft-allow unknown model IDs avoids hard 422 on catalog drift. Primary failure triggers cross-provider fallback; template path remains last resort.

5.10 Compliance and audit (Wave C)

Compliance module scores control alignment and surfaces gaps/evidence. Audit events form a hash chain; summary/integrity APIs support executive export packages for board-facing narratives.

Chapter 6 - Implementation

6.1 Technology stack

Layer	Technology
Backend	Python 3, FastAPI, Pydantic, pytest
Frontend	React, CRA/Vite-compatible SPA patterns, Recharts
Data	MongoDB, LanceDB
AI	Multi-provider LLM APIs, hybrid RAG
E2E	Playwright
Ops	Docker Compose, Kubernetes/Helm, GitHub Actions

6.2 Backend modules (selected)

Module	Role
parsers.py / broader parsers	Multi-format ingest
ioc_extractor.py	IoC extraction
enrichment.py	TI live/mock
attack_mapping.py	ATT&CK heuristics
vector_rag / KB	Hybrid retrieval
playbook_agent	Structured IR playbooks
hitl_gate.py	Review policy
llm_provider	Catalog + fallback
analytics_service	KPIs v3 (events, IoCs, techniques)
compliance / audit	Score, chain, export
golden_eval.py	Offline IR benchmark

6.3 Frontend routes (selected)

Login - Dashboard - Upload - Incidents - Incident Workspace - Hunt - Analytics - Review - Audit - Compliance - Knowledge - Settings - Ops Health - Golden Benchmark - Roadmap

Dashboard uses Promise.all for atomic KPI/incident load, formatMetricValue for stable formatting, and opt-in only REACT_APP_DASHBOARD_DEMO_FALLBACK (unset = live data / honest zeros).

6.4 Configuration and secrets

.env + Settings vault; secrets never returned in plaintext via API. Weak JWT rejected outside lab modes. OIDC scaffold present but password login is default.

6.5 Notable APIs

OpenAPI: docs/openapi.json. Dual mount /api and /api/v1. Key groups: auth, upload/jobs, incidents/workspace, review, hunt, settings/LLM catalog, compliance, audit, eval/golden.

6.6 CI/CD

GitHub Actions run unit/integration tests, golden IR gates, and related checks. Playwright smoke covers critical UI paths (maintain testids as UI evolves).

Chapter 7 - Testing & evaluation

7.1 Test strategy

Layer	Scope
Unit	Parsers, JSON resilience, HiTL, RBAC, audit
Integration	Pipeline isolation, enrichment mock, workspace APIs
Golden offline	37-case IR metrics (no Mongo/LLM required)
E2E	Playwright smoke / flows
Manual	Demo script, screenshot pack, TI live keys

Master catalog: appendices/A_test_case_catalog.md (TC-AUTH, TC-ING, TC-TI, TC-ATK, TC-AI, TC-RAG, TC-HITL, TC-WS, TC-DASH, TC-CMP, TC-AUD, TC-RES, ...).

7.2 Golden IR results (2026-07-26)

Metric	Threshold	Result	Pass
n_cases	>= 30	37	OK
mean_ioc_f1	>= 0.85	0.982	OK
mean_technique_recall	>= 0.80	0.930	OK
mean_grounding	>= 0.50	1.000	OK
full_phase_fraction	>= 1.0	1.000	OK
mean_latency_s	<= 7.0	0.001	OK
n_errors	0	0	OK
failures	[]	[]	OK

Command: `pytest backend/tests/test_golden_benchmark.py -q` (from repo conventions).

7.3 Broader automated suite

Representative suites (compliance, audit, LLM provider, RBAC, hunt, golden) were executed in development with 51+ tests passed on the Wave C resilience branch. Full matrix status should be filled in Appendix A after formal sign-off runs.

7.4 RAG / retrieval notes

Hybrid search returns scored hits; BM25 remains available if vectors are disabled. Retrieval pairs support offline checks; full RAGAS board metrics remain optional future work (not required for golden CI).

7.5 Security tests

RBAC matrix denies analyst settings mutation and unauthorized review. Hardening tests cover weak secrets, lockout, and session behavior. Prompt-injection notes are delimited without tool execution.

7.6 Usability / demo path

docs/DEMO_SCRIPT.md targets a <10 minute golden path: login -> sample upload -> workspace -> playbook/grounding -> HiTL approve -> compliance/audit glance. 5-minute video is a student deliverable for viva.

7.7 Limitations of evaluation

- Live LLM quality is not gated offline (template path dominates CI)
 - Mock TI is default without keys
 - Heuristic ATT&CK can false-positive technique IDs
 - Load/perf is pilot-class, not 500-user certified
 - E2E testid drift may require maintenance
-

Chapter 8 - Results & discussion

8.1 Product outcomes vs Project 4

Capstone expectation	ACTIRA outcome
Log parse + IoC	Multi-format + golden F1 ~0.98
TI enrichment	Multi-vendor + mock default
ATT&CK	Heuristic + heatmap + filters
RAG playbooks	Hybrid LanceDB + citations
HiTL	Severity + grounding gates
Dashboard	Live KPIs (demo opt-in)
Gradio UI baseline	React enterprise shell
Chroma baseline	LanceDB hybrid (ADR)
LangGraph multi-agent	Modular pipeline (honest framing)

8.2 Sample workflow outcomes

Analysts obtain: extracted IoCs, enrichment status (mock/live), technique list, playbook JSON with phases and citations, grounding score, optional RCA, and review state. Executives obtain compliance alignment and export packs without claiming certification.

8.3 Error analysis

Issue	Mitigation
False ATT&CK hits	HiTL + reviewer expertise
LLM JSON noise	parse_llm_json + template fallback
Empty dashboard misread	Live default; zeros when empty; no silent DEMO
Provider/model drift	Expanded catalog + soft-allow + fallback
Incident 404 hang	Explicit error/404 UI

8.4 Enterprise readiness

Board score 78/100 - Enterprise Pilot Ready (single-tenant). Strengths: documentation, AI IR narrative, workspace, golden eval, Wave C compliance/audit. Gaps: multi-tenant, full SSO JWKS, scale certification, remaining UX P0/P1 (Login marketing honesty, demo video/screenshots).

8.5 Screenshots

Figures live under this pack:

- assets/screenshots/01_login.png ... 12_architecture.png - live light-theme UI captures (Playwright: capture_screenshots.py)
- assets/figures/12_architecture.svg (light enterprise architecture poster), data_flow.svg, plus Mermaid sources

Embedded as Figures 1-12 in PROJECT_REPORT.pdf (one figure per page for readability).
Regenerate with `python docs/capstone/export_report_pdf.py`.

Chapter 9 - Challenges & mitigations

#	Challenge	Mitigation in ACTIRA
1	Large-scale logs	Job queue, ZIP limits; not real-time SIEM
2	Correlation accuracy	Heuristic ATT&CK + timeline + HiTL
3	False positives	Grounding score + review queue
4	TI integration cost/keys	Multi-vendor + mock default + vault
5	Contextual IR quality	Hybrid RAG + NIST-style phases + citations
6	Scalability	Single-tenant pilot packaging
7	HiTL coordination	Review queue, claim, audit
8	Privacy / secrets	Vault, RBAC, redaction options

Chapter 10 - Conclusion & future work

10.1 Conclusion

ACTIRA delivers a complete capstone-grade human-gated AI IR advisor: multi-format ingest, IoC/TI/ATT&CK, hybrid RAG playbooks, investigation workspace, HiTL, audit integrity, compliance alignment, multi-provider LLM resilience, and offline golden evaluation with strong CI metrics. It meets and exceeds TalentSprint Project 4 baseline expectations while remaining honest about non-goals versus hyperscale SIEM/XDR.

10.2 Future work

Horizon	Items
Submission close	Demo video pack closed in-repo (assets/video/ + DEMO_VIDEO_5MIN.md); optional VO dub / portal upload
Documented stretch (not demo-blocking)	Default real SBERT + broader KB corpus; continuous compliance automation; Hunt/Lance hybrid lake search - see docs/product/PRODUCT_HONESTY.md
Next release	SSO JWKS hardening, rate limits, E2E expansion
v2.0	Multi-tenant, connectors, commercial pilot
v3.0	Gated SOAR, forensics agent, formal multi-agent roster UX, RAGAS board

Trust & honesty surfaces (2026-07-27 close)

ACTIRA surfaces explicit non-claims in product UI: Hunt is case-pool scoring (not SIEM); Audit is hash-chained best-effort (not WORM); Analytics cache hit/miss/TTL footer; KB default hash embedder banner; Compliance assumed vs live-verified provenance. Dynamic audit actions, custom KB admin manager, Analytics drill-through to Hunt/Incidents, and live-probe unit tests close the remaining trust/UX depth items short of the demo video.

10.3 Ethical statement

ACTIRA is advisory. High-risk recommendations require human accountability. AI outputs must not be treated as unsupervised execution authority. Evaluators and operators should verify citations and TI freshness before action.

References

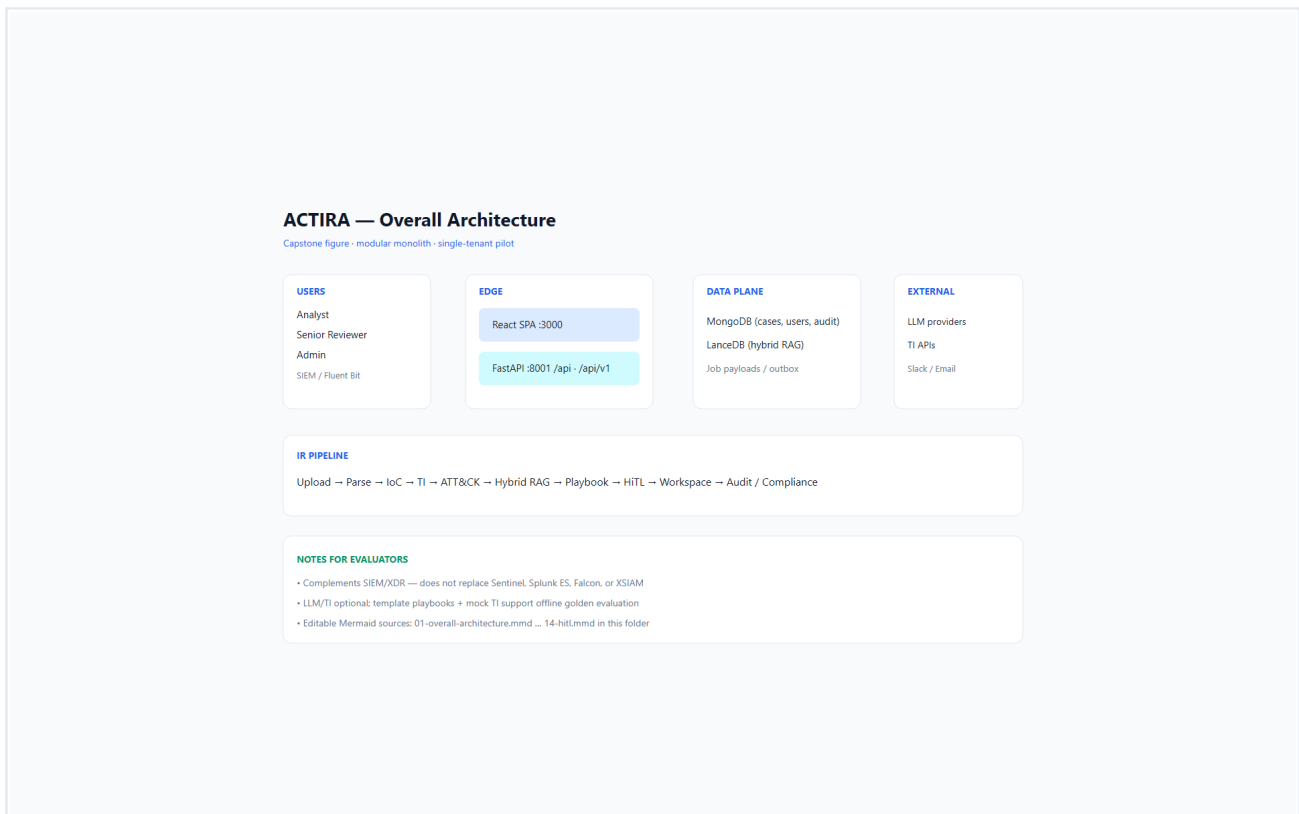
- TalentSprint / IISc track - Capstone Projects List (GenAI C2), Project 4 brief.
 - Lewis, P. et al. (2020). Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks.
 - MITRE ATT&CK Framework - <https://attack.mitre.org/>
 - NIST SP 800-61 - Computer Security Incident Handling Guide.
 - Vendor documentation: AbuseIPDB, VirusTotal (and configured TI providers).
 - Internal product docs and this pack: docs/capstone/* (board, appendices, presentation).
 - Enterprise board review: board/CAPSTONE_BOARD_REVIEW_AND_SUBMISSION.md (2026-07-26).
-

Architecture detail (submission posters)

ACTIRA is a modular monolith optimized for single-tenant pilot reliability: React SPA on the edge, FastAPI dual mounts (/api and /api/v1), MongoDB for cases/users/audit, LanceDB for hybrid BM25+vector RAG, and optional external LLM/TI APIs. The IR pipeline is job-queued: Upload -> Parse -> IoC -> TI -> ATT&CK -> Hybrid RAG -> Playbook -> HiTL -> Workspace -> Audit/Compliance.

Positioning for evaluators: complements SIEM/XDR dual-run pilots; does not replace Sentinel, Splunk ES, Falcon, or XSIAM. LLM and TI keys are optional - template playbooks and mock TI keep offline golden evaluation deterministic.

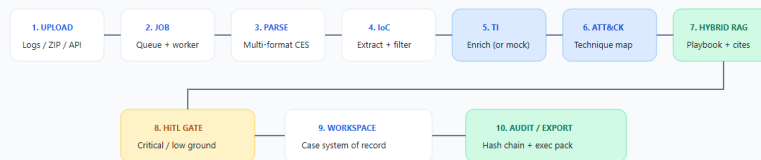
The five posters below are the detailed architecture set used in the viva deck and demo video. Editable SVG/Mermaid sources live under docs/capstone/assets/figures/. PNG renders are produced by capture_screenshots.py (Playwright SVG -> PNG).

Figure A. Overall architecture poster

Top-level context for evaluators: users (analyst/reviewer/admin/SIEM ingest), edge (React + FastAPI), data plane (MongoDB + LanceDB), and optional external LLM/TI. The IR pipeline strip states the job-queued path from upload through audit/compliance.

Figure B. Data flow - upload to review**ACTIRA — Data flow (upload to review)**

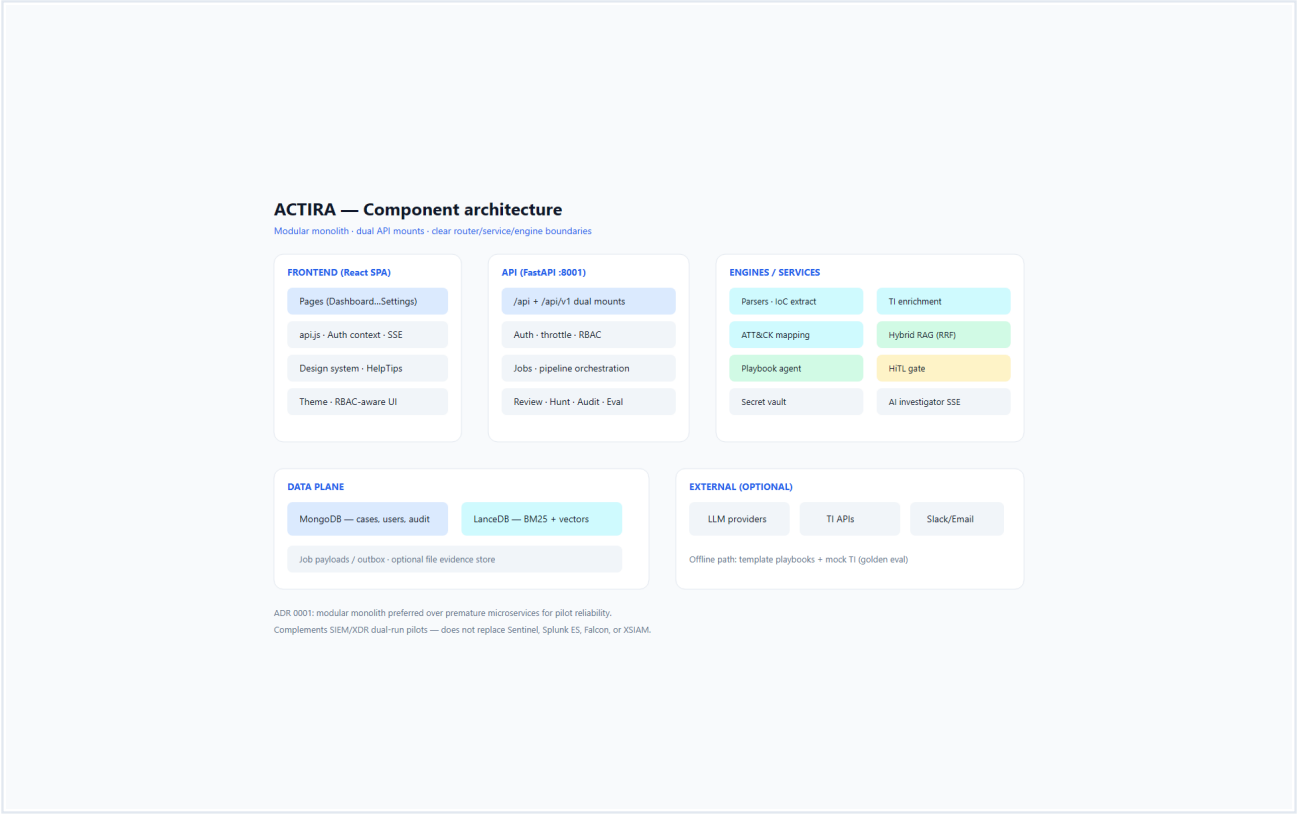
Job-queued IR pipeline • modular stages • HITL gate before high-risk closure

**EVALUATOR NOTES**

- Stages are deterministic offline: template playbooks + mock TI when LLM/TI keys are absent.
- HITL: critical severity or low grounding_score forces pending_review (race-safe approve/reject).

Ten-stage pipeline: Upload, Job, Parse (CES), IoC, TI (or mock), ATT&CK, Hybrid RAG playbook, HiTL gate, Workspace, Audit/export. Offline golden evaluation keeps template playbooks and mock TI so CI remains deterministic without live API keys.

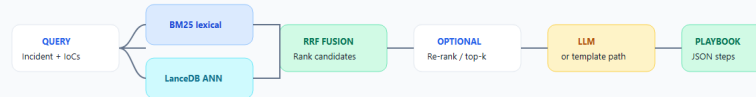
Figure C. Component architecture



Frontend pages/design system, FastAPI routers (auth, jobs, review, hunt, audit), engines (parsers, IoC, enrichment, ATT&CK, hybrid RAG, playbook agent, HiTL, vault, investigator SSE), and data/external planes. ADR 0001 prefers modular monolith over premature microservices.

Figure D. Hybrid RAG playbook pipeline**ACTIRA — Hybrid RAG playbook pipeline**

BM25 + dense vectors - RRF fusion - citation allow-list - grounding score

**TRUST CONTROLS (SUBMISSION-CRITICAL)**

1. Citation allow-list: playbook citation_ids must be a subset of retrieved knowledge-base IDs.
 2. Grounding score [0-1]: low grounding or critical severity forces HiTL pending_review.
 3. Multi-provider LLM catalog with cross-provider fallback; template playbook is last resort.
- Honest framing: modular agentic pipeline stages — not a full multi-agent swarm product.

Query construction from incident context, BM25 + LanceDB ANN fused by RRF, optional re-rank, LLM or template generation, citation allow-list filter, and grounding score. Trust controls are first-class: citations must subset retrieved KB IDs; low grounding triggers HiTL.

Figure E. Human-in-the-Loop policy

ACTIRA — Human-in-the-Loop policy

Severity + grounding gates + race-safe review + audit hash chain



OPERATIONAL GUARANTEES

- Senior reviewer approve/reject with comments: concurrent double-approve returns 409 (race-safe).
- Auto-approve never bypasses the severity gate — critical work always needs a human.
- Audit events form a best-effort SHA-256 integrity chain (not WORM storage).
- Review queue is the product surface for board/viva demos of mandatory human gates.

Roles: analyst (investigate) · senior_reviewer (approve) · admin (settings / governance).

Decision tree: severity gate, grounding threshold, optional auto-approve (never bypasses severity), pending_review path, race-safe reviewer actions, and audit integrity notes. Roles: analyst investigate, senior_reviewer approve, admin govern.

Layer responsibilities

Layer	Components	Responsibilities
Edge UI	React SPA	Auth, Dashboard, Upload, Workspace, Review, Hunt, Settings, Compliance
API	FastAPI /api + /api/v1	Jobs, pipeline, RBAC, SSE investigator, export APIs
Engines	Parse/loC/TI/ATT&CK/RAG/HiTL	Deterministic + optional LLM stages
Data	MongoDB + LanceDB	Cases, users, audit chain; hybrid retrieval index
External	LLM / TI / Slack	Optional; mock/template offline path

Security & governance architecture

Control	Mechanism
AuthN	Password login + cookie JWT; logout; OIDC scaffold
AuthZ	RBAC: analyst / senior_reviewer / admin
Secrets	Settings vault encrypt-at-rest; never return raw keys
Ingest safety	ZIP bomb / size limits; pipeline isolation
Audit	SHA-256 integrity chain; summary + executive export
Compliance	Alignment score + gaps + evidence (not certification)

AI / RAG architecture

- Hybrid retrieval: BM25 + LanceDB dense vectors fused with Reciprocal Rank Fusion (RRF)
- Citation allow-list: playbook citation_ids must subset retrieved KB IDs
- Grounding score 0-1; low grounding or critical severity -> HiTL pending_review
- Multi-provider LLM catalog with cross-provider fallback; template last resort
- Honest framing: modular agentic pipeline stages, not a full multi-agent swarm product

How to read the architecture figures

- Figure A (overall): context diagram - who uses ACTIRA and which planes they touch
- Figure B (data flow): ordered pipeline stages from upload through audit/export
- Figure C (components): frontend pages, FastAPI routers, engines, data/external planes
- Figure D (RAG): hybrid retrieval, citation filter, grounding, template offline path
- Figure E (HiTL): severity/grounding gates, race-safe review, audit integrity notes

Figures - Screenshots & architecture

The following figures are live light-theme captures from the ACTIRA lab environment (Playwright: docs/capstone/capture_screenshots.py) plus detailed architecture posters. Each figure is placed on its own page with a short narration for evaluators.

UI theme: light enterprise shell (default for this Final Capstone Project pack). Architecture posters use the same light palette as the product screenshots. Figures A-E in the Architecture detail section expand system design beyond Figure 12.

Figure 1. Login - platform status probe (honest health, not fake KPIs)

ACTIRA
AGENTIC TI & IR ADVISOR

Enterprise AI Security Operations Platform

Transform security events into actionable intelligence.

Agentic Cybersecurity Threat Intelligence & Incident Response Advisor is an enterprise-grade platform leveraging agentic AI to automate threat detection, threat intelligence enrichment, MITRE ATT&CK mapping, and incident response playbook generation — backed by human analyst approval gates.

AI Threat Detection
Continuous, model-driven triage of raw security events.

Threat Intelligence
Automated enrichment against live threat intel sources.

MITRE ATT&CK Mapping
Findings mapped to tactics and techniques automatically.

Multi-Agent Reasoning
Specialized agents collaborate on complex investigations.

IR Playbook Generation
Citation-grounded response playbooks, ready to execute.

RAG Grounding
Every recommendation traced back to source evidence.

Evidence Collection
IoCs and artifacts gathered and organized for review.

Human Approval Workflow
Critical actions always pass through analyst sign-off.

■ PLATFORM STATUS (PROBED)

API/Mongo reflect a live /hea1th check. LLM and TI are configured after sign-in — not shown as connected until verified. Live tenant KPIs appear on the Dashboard after login (demo fill is opt-in only).

BACKEND API
● Reachable

MONGODB
● Up

LLM
○ After sign-in

THREAT INTEL
○ Keys optional

PIPELINE
Parse → IoC → TI

HITL
Critical gated

ATT&CK
Heuristic map

RAG
Hybrid BM25+vec

EVAL
Golden IR CI

PROJECT TEAM • GROUP 1

Advanced Certification Programme in Agentic & Generative AI

Abhishek Patre

Aditya Sharma

Banshan Mukhar Das

Gaurav Eary

Nishant Ramesh Rao Patil

Prajwal B R

Praveen S N

Sarvesh Sood

Sindhu Subramanya

Vesalapu Satya Venkat...

Enterprise Capstone

⚙️ V2 ENTERPRISE DEMO

SECURE SIGN-IN

Welcome back, analyst.

Role-Based Access | JWT Authentication | Human-in-the-Loop

EMAIL
you@company.com

PASSWORD
***** [Forgot password?](#)

☐ Remember me on this device

Sign in →

Need an account? Register

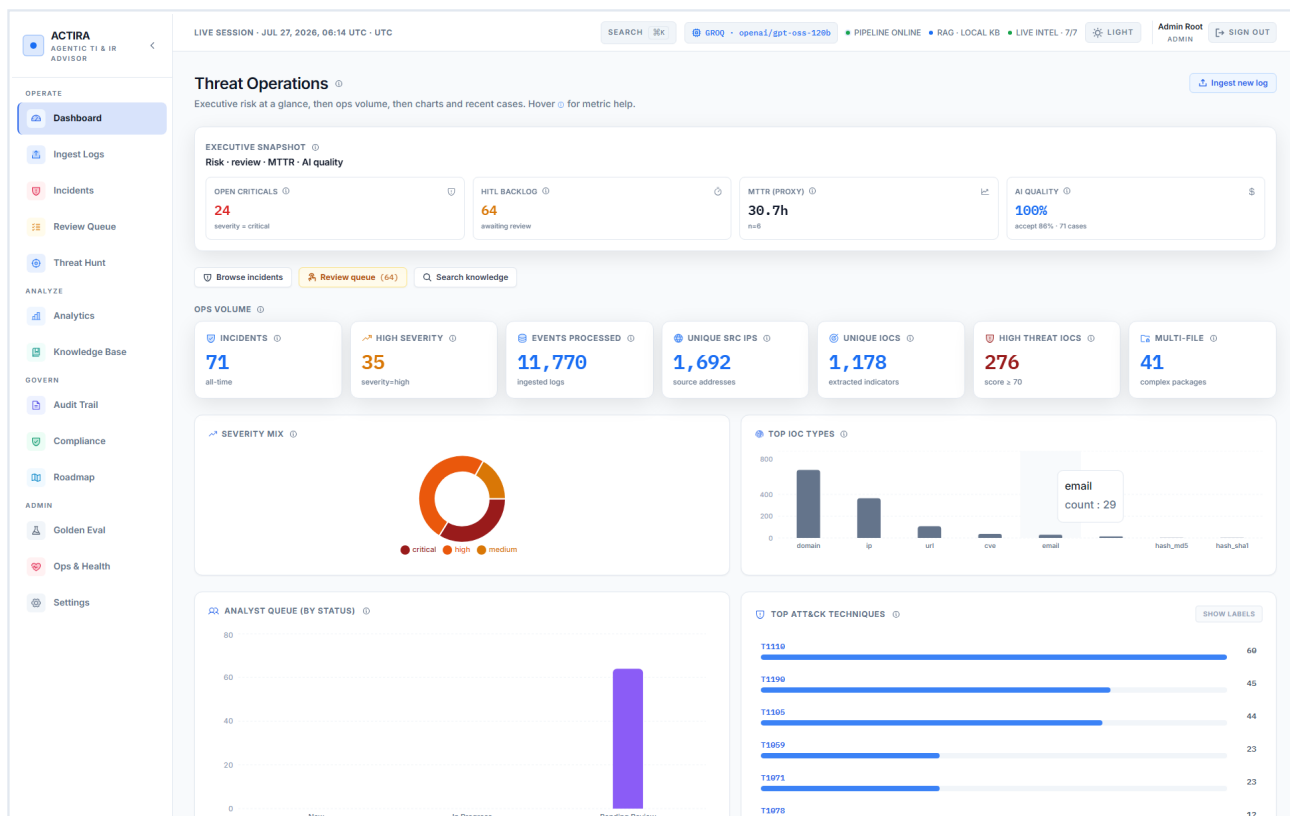
DEMO OPERATORS
Dev environment only — autofills preset testing credentials.

Analyst analyst@soc.example.com

Senior Reviewer reviewer@soc.example.com

Admin admin@soc.example.com

Entry surface for analysts, senior reviewers, and admins. The left pane documents product capabilities; the right pane is the credential form with optional demo autofill (autofill does not authenticate until Sign in). Status tiles probe live backend/Mongo health rather than fabricating tenant KPIs - live metrics appear only after authentication on the Dashboard.

Figure 2. Dashboard - live KPIs and ATT&CK heatmap

Post-login home: severity mix, incident volume, IoC/event counters, and an ATT&CK technique heatmap driven from Mongo-backed analytics (short-lived cache). Empty tenants show zeros, not demo filler, unless an explicit demo-fallback flag is enabled and disclosed by banner.

Figure 3. Upload / ingest - multi-format logs and job queue

ACTIRA
AGENTLESS TI & IR
ADVISOR

LIVE SESSION - JUL 27, 2026, 06:14 UTC - UTC

SEARCH [X] GPO - openai/gpt-oss-128b PIPELINE ONLINE RAG - LOCAL KB LIVE INTEL - 7/7 LIGHT Admin Root ADMIN SIGN OUT

Ingest Logs

Drop logs, multi-file packages, or ZIPs. Format is auto-detected; events normalize to CES and correlate into one incident per job (not multi-tenant SIEM fan-out).

Stage sample... 3-file bundle Paste log Refresh

Drop logs or a ZIP package
Single file, multi-file, or incident-package ZIP - max 20 files - 25 MB each

APACHE NOINX SYSLOG JSON CSV CEF LEAF CLOUDTRAIL
SURICATA ZEEK SYSMON DEFENDER EVT* ZIP

PIPELINE EXECUTION FLOW

1. Format detection per file -> CES normalization
2. Cross-log correlation (IP - user - host - hash - domain)
3. IoC extraction -> parallel threat-intel enrichment
4. MITRE ATT&CK technique inference
5. Citation-grounded playbook via LLM
6. HTL routing on critical severity / low grounding

RECENT JOBS QUEUE

ALL 58 ACTIVE 0 DONE 40 FAILED 4 auto-refresh 3s

apache.log SINGLE
ID: 4780a8cc - 254 B Open Incident - DONE 579ms

apache.log apache - 3 evt

QUEUED PARSING EXTRACTING CORRELATING ENRICHING PLAYBOOK COMPLETE

batch-3-files BATCH
ID: 98215c29 - 861 B - 3 files Open Incident - DONE 6787ms

apache.log apache - 3 evt **syslog.log** syslog - 4 evt

firewall.csv csv - 3 evt

QUEUED PARSING EXTRACTING CORRELATING ENRICHING PLAYBOOK COMPLETE

batch-3-files BATCH
ID: ca134849 - 861 B - 3 files Open Incident - DONE

apache.log apache - 3 evt **syslog.log** syslog - 4 evt

firewall.csv csv - 3 evt

QUEUED PARSING EXTRACTING CORRELATING ENRICHING PLAYBOOK COMPLETE

batch-3-files BATCH
ID: b6da3d22 - 861 B - 3 files Resuming FAILED

QUEUED PARSING EXTRACTING CORRELATING ENRICHING PLAYBOOK COMPLETE

Error: No module named 'mongo_util'

batch-3-files BATCH
ID: 8cc376ff - 861 B - 3 files Resuming FAILED

QUEUED PARSING EXTRACTING CORRELATING ENRICHING PLAYBOOK COMPLETE

Error: No module named 'enrichment'

batch-3-files BATCH
ID: a699086 - 861 B - 3 files Resuming FAILED

QUEUED PARSING EXTRACTING CORRELATING ENRICHING PLAYBOOK COMPLETE

Error: No module named 'enrichment_cache'

batch-3-files BATCH Resuming FAILED

Analyst evidence intake: multi-file and ZIP upload, sample-bundle staging, and job-queue visibility. The pipeline is asynchronous (parse, IoC, TI, ATT&CK, RAG, playbook) rather than a chat session - matching the modular agentic design described in Chapter 4.

Figure 4. Incidents list - severity and filters

ACTIRA
AGENTIC TI & IR
ADVISOR

LIVE SESSION - JUL 27, 2026, 06:15 UTC - UTC

SEARCH [X] GROQ - openai/gpt-oss-128b PIPELINE ONLINE RAG - LOCAL KB LIVE INTEL - 7/7 LIGHT Admin Root ADMIN SIGN OUT

Incident Cases

Showing 25 of 71 cases - server page.

IN VIEW 4 critical 13 high 24 HTL queue 1 score ≥ 70 Hunt Instead

Filters Search ID, title, summary, technique. All statuses All severities Technique e.g. T11 Any threat HTL only

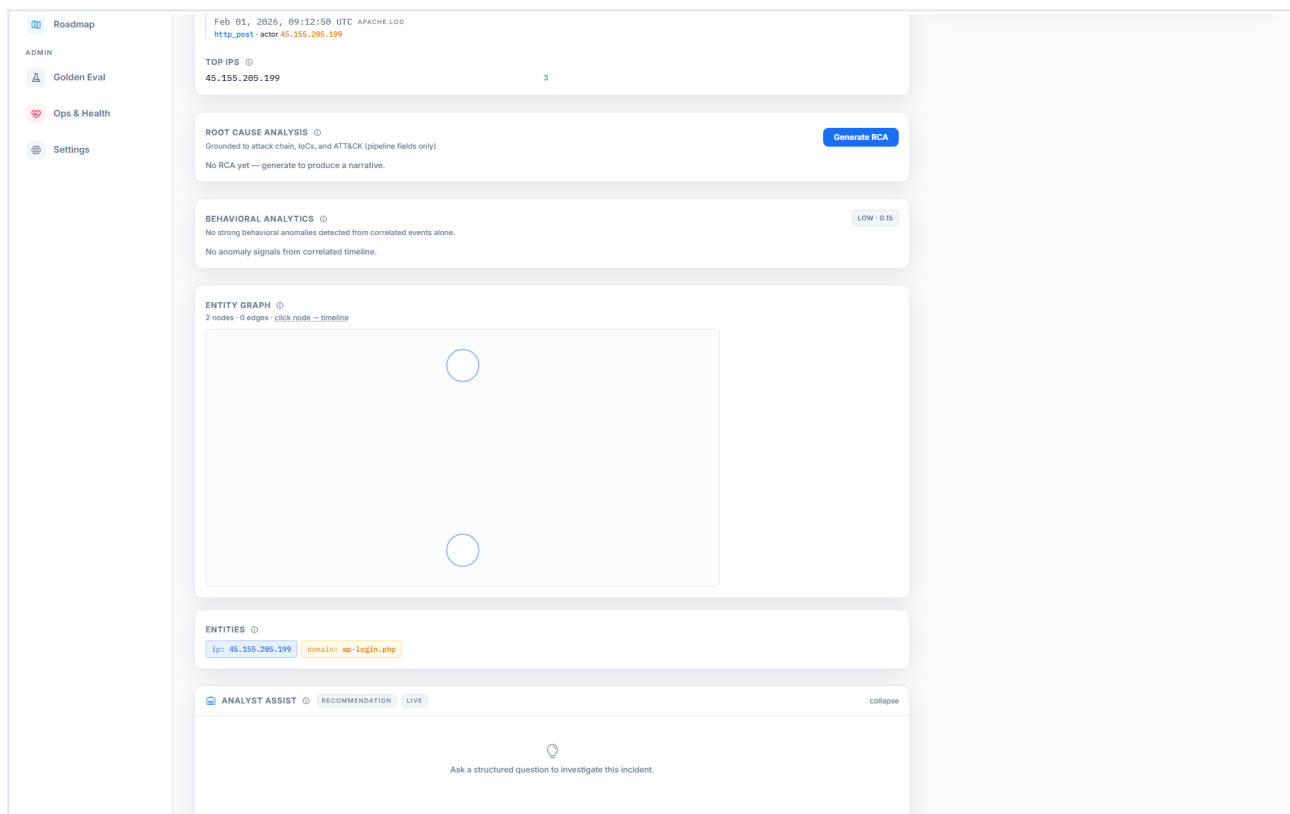
Severity	Incident Title & ID	Status	Threat	Ground	Tech	IoCs	Created	ACTIONS
HIGH	Cross-log correlation on ip=45.155.205.199 (1 files) 3 events - 1 unique IP - 0 users - 0 hosts. Strongest cross-file link: ip-45.155.205.19... a0953277-080a-422a-928d-559ecf824353	APPROVED	35.8	1	-	2	17h ago	Investigate
HIGH	Exploit Public-Facing Application activity detected (T1190) Correlated across 3 log files (apache.log, syslog.log, firewall.csv). Detected T1190... 0170132a-b4fc-43a5-b2f5-72a63d26536 HTL	PENDING REVIEW	33.2	1	3	5	27h ago	Investigate
HIGH	Exploit Public-Facing Application activity detected (T1190) Correlated across 3 log files (apache.log, syslog.log, firewall.csv). Detected T1190... 23099b78-9a4d-46ff-b2ab-95a19e1867e HTL	PENDING REVIEW	33.2	1	3	5	32h ago	Investigate
CRITICAL	Network Service Discovery activity detected (T1046) Correlated across 4 log files (apache.log, syslog.log, firewall.csv, dataset v2.json)... 4346da34-329e-453b-8a44-c3a091a5f4a8 HTL	PENDING REVIEW	56.4	1	12	58	41h ago	Investigate
HIGH	Exploit Public-Facing Application activity detected (T1190) Correlated across 3 log files (apache.log, syslog.log, firewall.csv). Detected T1190... 4f222a52-c25c-48ab-935b-fc992a5528a4 HTL	PENDING REVIEW	24.8	1	3	5	42h ago	Investigate
HIGH	Exploit Public-Facing Application activity detected (T1190) Correlated across 3 log files (apache.log, syslog.log, firewall.csv). Detected T1190... a8ba196c-a771-4dbb-a8f3-88ba096a354a HTL	PENDING REVIEW	24.8	1	3	5	44h ago	Investigate
HIGH	Exploit Public-Facing Application activity detected (T1190) Correlated across 3 log files (apache.log, syslog.log, firewall.csv). Detected T1190... 5c0906a9-a73b-456f-a353-8f25e3771715 HTL	PENDING REVIEW	24.8	1	3	5	2d ago	Investigate

Showing 1-25 of 71

< Prev 1 / 3 Next >

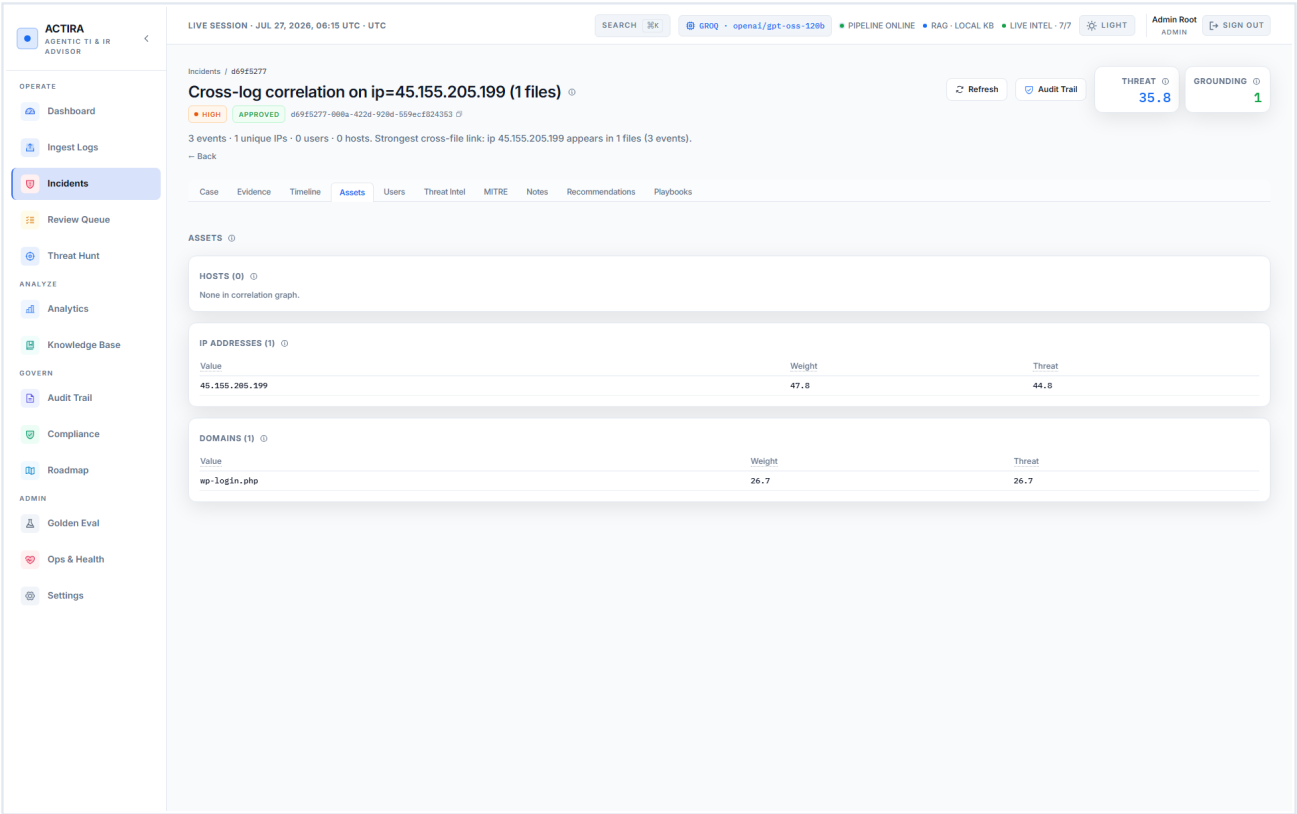
OPERATE
Dashboard
Ingest Logs
Incidents
Review Queue
Threat Hunt
ANALYZE
Analytics
Knowledge Base
GOVERN
Audit Trail
Compliance
Roadmap
ADMIN
Golden Eval
Ops & Health
Settings

Case inventory with severity filters, search, and deep links into the investigation workspace. Each row is a first-class incident document in MongoDB - the product system of record for IR narrative, not a transient chat thread.

Figure 5. Investigation workspace - case system of record

Single-pane investigation: case metadata, evidence, timeline, techniques, notes, and AI investigator stream. URL tab state supports shareable deep links for dual-run SIEM pilots.

Figure 6. Entity graph / assets view



Entity/assets graph derived from correlated CES events and IoCs. Complements timeline and MITRE views so reviewers can see lateral relationships without leaving the case.

Figure 7. IR playbook - phases, citations, grounding

The screenshot displays the ACTIRA interface for an incident titled "Cross-log correlation on ip=45.155.205.199 (1 files)". The interface includes a sidebar with navigation options like Dashboard, Ingest Logs, Incidents, Review Queue, Threat Hunt, Analytics, Knowledge Base, Audit Trail, Compliance, Roadmap, Golden Eval, Ops & Health, and Settings. The main content area shows the incident details, including a summary of 3 events, 1 unique IP, 0 users, and 0 hosts. A "RESPONSE PLAYBOOK" is generated, listing 10 tasks across four phases: CONTAINMENT, ERADICATION, RECOVERY, and LESSONS LEARNED. Each task is associated with specific citation chips (e.g., PB-BRUTEFORCE, TS078, PB-RANSOMWARE, TS058, NIST-800-61-3.1, PB-BRUTEFORCE, PB-PHISHING).

Incident Details:

- Incidents / d69f5277
- Cross-log correlation on ip=45.155.205.199 (1 files)**
- THREAT: 35.8
- GROUNDING: 1
- 3 events · 1 unique IPs · 0 users · 0 hosts. Strongest cross-file link: ip 45.155.205.199 appears in 1 files (3 events).
- Back

RESPONSE PLAYBOOK

Generated by groq/openai/gpt-oss-120b · grounding 1

CONTAINMENT

- 01 Block source IP 45.155.205.199 at the edge firewall to stop further traffic (PB-BRUTEFORCE)
- 02 Lock any user accounts that attempted authentication via wp-login.php (PB-BRUTEFORCE | TS078)
- 03 Enable multi-factor authentication for the locked accounts and any other privileged users (PB-BRUTEFORCE | TS078)
- 04 Review VPN and RDP logs for successful logins originating from the malicious IP (PB-BRUTEFORCE)
- 05 Sinkhole or block the wp-login.php domain at DNS and firewall to prevent beaconing (PB-C2)

ERADICATION

- 06 Rotate credentials for all accounts that may have been exposed (PB-BRUTEFORCE)
- 07 Capture network PCAP, extract any implants, and remove malicious artifacts from affected hosts (PB-C2)

RECOVERY

- 08 Restore affected systems from immutable backups and verify integrity before reconnecting to network (PB-RANSOMWARE | TS058)
- 09 Monitor for repeat brute-force attempts and update detection thresholds accordingly (NIST-800-61-3.1 | PB-BRUTEFORCE)
- 10 Notify users of the incident, provide phishing awareness training, and run tabletop exercises (PB-PHISHING)

LESSONS LEARNED

Hybrid-RAG playbook with containment/eradication/recovery/lessons phases, citation chips bound to the KB allow-list, and a grounding score. Low grounding or critical severity forces HiTL pending_review before closure.

Figure 8. Human-in-the-Loop review queue

The screenshot displays the ACTIRA Reviewer Queue interface. The top navigation bar includes the ACTIRA logo, a live session status (JUL 27, 2026, 06:15 UTC - UTC), search functionality, and system status indicators (PIPELINE ONLINE, RAG - LOCAL KB, LIVE INTEL - 7/7). The left sidebar contains navigation links for Dashboard, Ingest Logs, Incidents, Review Queue (selected), Threat Hunt, Analytics, Knowledge Base, Audit Trail, Compliance, Roadmap, Golden Eval, Ops & Health, and Settings.

The main content area is titled "Reviewer Queue" and shows 64 cases needing review, sorted by threat_score (desc). The interface includes filters for TRIAGE (Search title, id, ioC, technique), All severity, All techniques, Min tl, Gs, 1, Techs, and IoCs. The sort options are Threat, Severity, Grounding, Created, and Title.

The queue displays several incidents, each with a severity level, title, ID, and a table of metrics (GROUNDING, IOCS, TECHS, THREAT). Each incident also has an "Approve" or "Reject" button and a "Quick Preview" button.

Severity	Title	ID	GROUNDING	IOCS	TECHS	THREAT
HIGH	Brute Force activity detected (T1110)	3882f538-8238-432a-9518-36389998953c	1	1	1	73.5
HIGH	Brute Force activity detected (T1110)	0b561580-6a6f-4ca4-b582-4a527742462	1	1	1	73.5
HIGH	Brute Force activity detected (T1110)	1cd90ca2-ba6b-481e-9a34-2a9793547bc3	1	1	1	73.5
CRITICAL	Brute Force activity detected (T1110)	a68a80f6-3a94-44f1-9ae7-d4f732941ae8	1	42	8	70.9
HIGH	Brute Force activity detected (T1110)	5882f538-8238-432a-9518-36389998953c	1	1	1	73.5
HIGH	Brute Force activity detected (T1110)	864432ba-562b-48b8-a82d-d45b4943b834	1	1	1	73.5
CRITICAL	Network Service Discovery activity detected (T1046)	3882f538-36f9-4a11-9c30-4aaf2338e73e	1	50	10	71.5
HIGH	PowerShell activity detected (T1059.001)	0ba332f4-8582-404d-8a3e-379d68aaba7a	1	50	4	70

Senior-reviewer queue for mandatory human gates. Approve/reject is race-safe (409 on double claim). Decisions write audit events into the integrity chain - best-effort hash chain, not WORM.

Figure 9. Threat hunting

The screenshot displays the ACTIRA Threat Hunting interface. The top navigation bar includes the ACTIRA logo, a live session status, search functionality, and user information. The left sidebar contains navigation links for various system components. The main content area is titled 'Threat Hunting' and includes a description of the case hunt feature. A 'HUNT QUERY' section allows users to input a natural-language query and select filters. Below this, a 'BEHAVIORAL HOTSPOTS' section displays a list of detected activities with their severity and score.

ACTIRA
AGENTIC TI & IR
ADVISOR

LIVE SESSION - JUL 27, 2026, 06:15 UTC - UTC

SEARCH [X] GPO - opena1/gpt-oss-129b PIPELINE ONLINE RAG - LOCAL KB LIVE INTEL - 7/7 LIGHT Admin Root ADMIN SIGN OUT

Threat Hunting

Natural-language hunt over recent incidents (rule-based intents + keyword scoring)

Case hunt, not SIEM. Scores the newest 5000 incidents (with optional severity/status filters). Does not query raw log lakes (KQL/SPL).

HUNT QUERY

Q. e.g. Find suspicious PowerShell or Show lateral movement

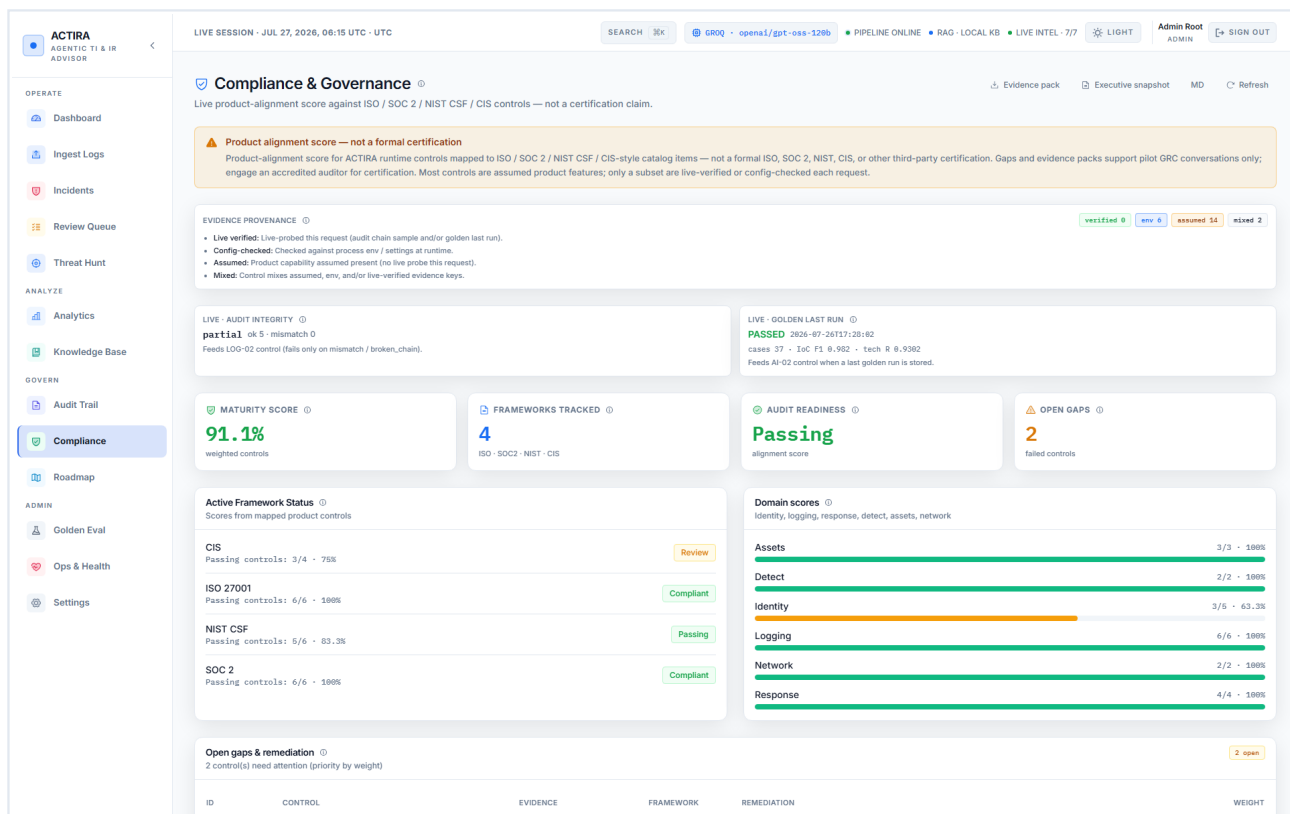
All severities All statuses Run hunt

Find suspicious PowerShell Show lateral movement Find ransomware indicators Show suspicious DNS Find persistence Find all encoded commands Show high severity brute force

BEHAVIORAL HOTSPOTS
Beaconing, login bursts, multi-host users, LOLBins, DNS volume

PowerShell activity detected (T1059.001)	CRITICAL	high 0.87	multi_host_user, lolbins
Network Service Discovery activity detected (T1046)	CRITICAL	high 0.82	severity_spike, lolbins
Network Service Discovery activity detected (T1046)	CRITICAL	medium 0.7	lolbins, severity_spike
Brute Force activity detected (T1110)	CRITICAL	high 0.7	severity_spike, lolbins
PowerShell activity detected (T1059.001)	CRITICAL	medium 0.7	lolbins, severity_spike
Brute Force activity detected (T1110)	CRITICAL	high 0.7	severity_spike, lolbins
PowerShell activity detected (T1059.001)	HIGH	medium 0.6	lolbins
Brute Force activity detected (T1110)	CRITICAL	medium 0.6	lolbins

Natural-language case hunt over a bounded recent incident window (not a SIEM log lake). Honesty banners state scoring limits so evaluators do not confuse case hunt with lake-scale hunt.

Figure 10. Compliance alignment score (not certification)

Product control-alignment score with assumed vs live-verified evidence and gap lists. Explicitly not ISO/SOC2 certification - suitable for board narrative packs and pilot readiness stories.

Figure 11. Settings - multi-provider LLM catalog

ACTIRA
AGENTIC TI & IR
ADVISOR

OPERATE
Dashboard
Ingest Logs
Incidents
Review Queue
Threat Hunt

ANALYZE
Analytics
Knowledge Base

GOVERN
Audit Trail
Compliance
Roadmap

ADMIN
Golden Eval
Ops & Health
Settings

LIVE SESSION - JUL 27, 2026, 06:15 UTC - UTC

SEARCH

GROQ - openai/gpt-oss-120b

PIPELINE ONLINE

RAG - LOCAL KB

LIVE INTEL - 7/7

LIGHT

Admin Root
ADMIN

SIGN OUT

Settings

Admin configuration for providers, HITL detection gates, threat intel keys, alerts, and browser UI preferences.

2 tips

LLM

Providers: Anthropic, OpenAI, Gemini, Groq

Model: GPT-OSS 120B (free tier) - free

GROQ API KEY (ACTIVE)

ALL PROVIDER KEYS (FOR FALLBACK)

Anthropic, OpenAI, Gemini, Groq keys

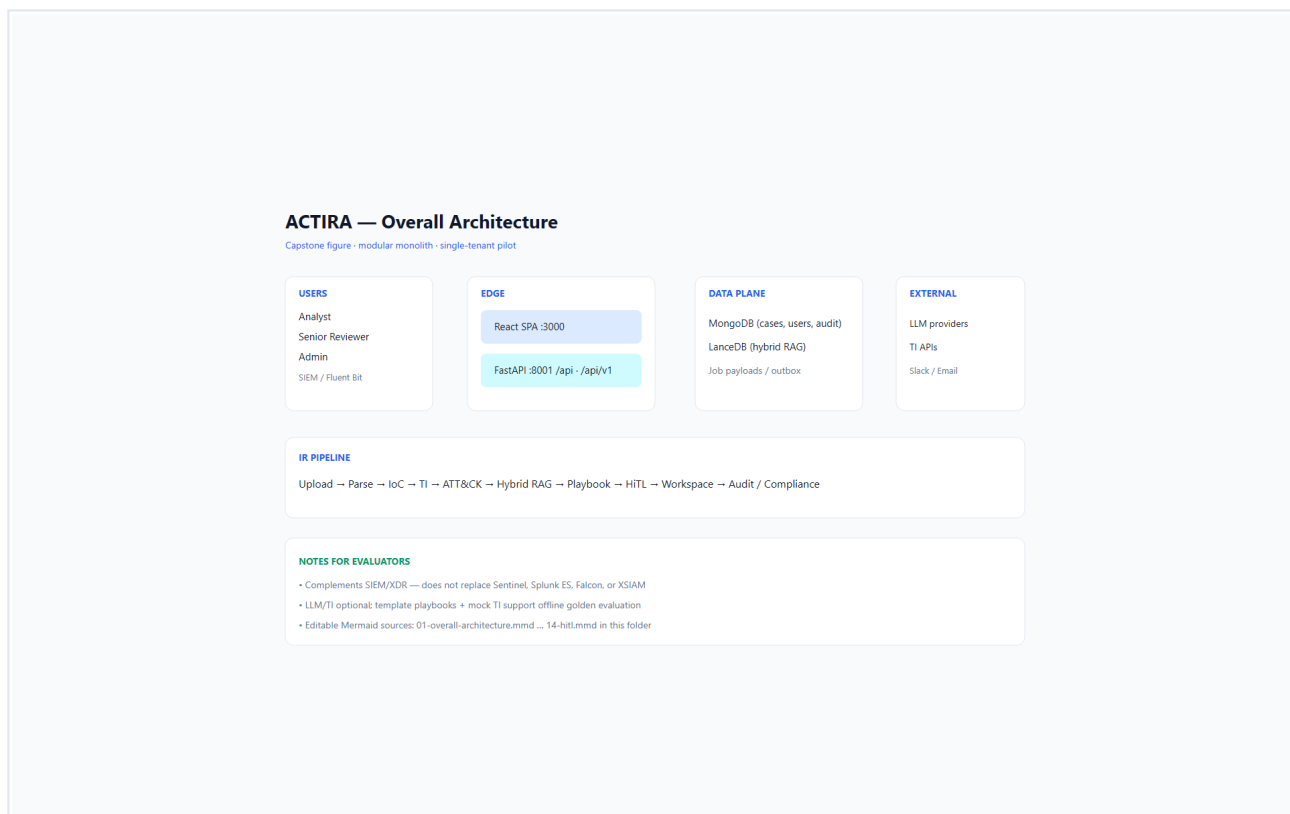
Active stack

Ops profile

Custom mix

Reset Recommended Save all settings

Admin LLM catalog: free/paid models, vaulted secrets (never returned raw), cross-provider fallback, and template-playbook offline path for deterministic golden evaluation.

Figure 12. System architecture overview (light enterprise poster)

Overall modular monolith: React SPA edge, FastAPI dual mounts (/api and /api/v1), MongoDB case/audit store, LanceDB hybrid RAG, optional LLM/TI. See Architecture detail for data-flow, component, RAG, and HiTL posters (Figures A-E).

Appendices - formal automation evidence

The following pages include the full detailed appendix pack (A-F) for this Final Capstone Project. Formal automated evidence (2026-07-27) is summarized first. Appendix E is included for completeness only - evaluation focus is product capability, not personnel.

Formal run (2026-07-27)

Suite	Result	Notes
Golden IR + Wave C + RBAC + Hardening	66 / 66 PASS	~18s, exit 0
Golden cases	37	IoC F1 0.982, technique recall 0.930
Mean grounding (template path)	1.000	CI offline path
Demo video + screenshots	Regenerated	Light theme, full product tour

Command: python -m pytest backend/tests/test_golden_benchmark.py
 backend/tests/test_compliance_score.py backend/tests/test_audit_intelligence.py
 backend/tests/test_llm_fallback_catalog.py backend/tests/test_executive_export.py
 backend/tests/test_rbac_matrix.py backend/tests/test_hardening.py -q

Appendix A - Test case catalog (detailed)

Source: docs/capstone/appendices/A_test_case_catalog.md

Location: docs/capstone/appendices/A_test_case_catalog.md

Product: ACTIRA - Agentic Cybersecurity Threat Intelligence & Incident Response Advisor

Purpose: Formal test catalog for evaluation report, viva, and regression evidence

Last updated: 2026-07-26

Automation map: pytest (backend/tests/), Playwright (frontend/e2e/), manual (M)

Parent report: ../PROJECT_REPORT.md

Legend

Field	Values
Priority	P0 Critical - P1 High - P2 Medium - P3 Low
Type	Functional - Security - API - UI - Performance - AI/RAG - Integration
Automation	Auto (pytest/Playwright) - Semi - Manual
Status	Pass / Fail / Blocked / Not run

1. Traceability to Capstone Project 4

Capstone capability	Test IDs
Log parse & IoC extract	TC-ING-001..., TC-PAR-001...
TI enrichment	TC-TI-001...
ATT&CK mapping	TC-ATK-001...
RAG + playbook	TC-AI-001..., TC-RAG-001...
HiTL	TC-HITL-001...
Dashboard	TC-DASH-001...
Investigation workspace	TC-WS-001...
Auth / RBAC	TC-AUTH-001...
Compliance / audit	TC-CMP-001..., TC-AUD-001...
Fallbacks / resilience	TC-RES-001...

2. Authentication & Authorization

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-AUTH-001	Login valid analyst	POST /auth/login with seeded analyst	200, cookie session, role analyst	P0	Security	Auto	test_hardenin g, e2e smoke
TC-AUTH-002	Login invalid password	Wrong password	401, lockout counter increments	P0	Security	Auto	hardening
TC-AUTH-003	Lockout after N failures	Fail login >= threshold	Locked until window	P0	Security	Auto	auth_throttle
TC-AUTH-004	RBAC: settings mutate admin only	Analyst PUT /settings	403	P0	Security	Auto	test_rbac_ma trix
TC-AUTH-005	RBAC: review senior/admin	Analyst POST review	403	P0	Security	Auto	rbac
TC-AUTH-006	Cookie session revalidate	Login -> GET /auth/me after 5m path	Role refreshed	P1	Security	Manual/Semi	auth.jsx
TC-AUTH-007	Logout clears cookie	POST /auth/logout	Subsequent API 401	P0	Security	Auto/e2e	smoke
TC-AUTH-008	Weak JWT rejected outside lab	Start API with weak secret ENV=prod	Fail start / refuse	P0	Security	Auto	hardening
TC-AUTH-009	Register creates analyst only	Public register	Role always analyst	P1	Security	Auto	auth
TC-AUTH-010	OIDC scaffold off by default	No OIDC env	Password login only	P1	Security	Manual	oidc

3. Ingest & Parsing

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-ING-001	Single log upload	Upload apache/syslog sample	Job queued -> completed, incident created	P0	Integration	Auto/Manual	pipeline, smoke
TC-ING-002	Multi-file ZIP	Upload ZIP package	One correlated incident, multi_file flag	P0	Integration	Manual/Auto	pipeline
TC-ING-003	ZIP bomb protection	Oversized nested ZIP	Rejected / safe fail	P0	Security	Auto	pipeline isolation

TC-ING-004	Suricata EVE parse	Upload Suricata JSON sample	Events parsed to CES	P1	Functional	Auto	broader_parsers
TC-ING-005	Zeek parse	Zeek log sample	Parsed fields present	P1	Functional	Auto	broader_parsers
TC-ING-006	Sysmon JSON	Sysmon sample	Process fields extracted	P1	Functional	Auto	broader_parsers
TC-ING-007	Defender parse	Defender sample	Parsed	P1	Functional	Auto	broader_parsers
TC-ING-008	Job status polling	After upload poll jobs	status transitions visible	P0	UI/API	Manual/e2e	Upload page
TC-ING-009	Sample bundle button	Click Stage 3-File Bundle	Files staged in queue	P1	UI	Manual	Upload
TC-PAR-001	IoC IP extraction	Log with IPs	IoCs type=ip	P0	Functional	Auto	golden
TC-PAR-002	IoC domain/url/hash	Mixed log	Correct types	P0	Functional	Auto	golden
TC-PAR-003	Parser isolation failure	One bad file in batch	Other files still process	P1	Functional	Auto	pipeline_isolation

4. Threat Intelligence & ATT&CK

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-TI-001	Mock enrichment without keys	Clear TI keys, ingest	IoC enrichment mock=true	P0	Functional	Auto	enrichment
TC-TI-002	Live AbuseIPDB when keyed	Set key, ingest IP	mock=false when API ok	P1	Integration	Manual	enrichment
TC-TI-003	FORCE MOCK_TI	Set env true	Always mock	P1	Functional	Auto	tests
TC-ATK-001	Keyword ATT&CK map	Brute force log	Techniques include T1110-class	P0	AI	Auto	attack_mapping, golden
TC-ATK-002	Heatmap counts	Open Dashboard heatmap	Counts match incidents	P1	UI	Manual	Dashboard
TC-ATK-003	Technique filter	Incidents ?technique=T1110	Filtered list	P1	Functional	Manual	Incidents

TC-ATK-004	Catalog matrix API	GET /attack/matrix	Columns/techniques	P2	API	Auto	attack_matrix
------------	--------------------	--------------------	--------------------	----	-----	------	---------------

5. AI / RAG / Playbooks / Investigator

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-AI-001	Playbook structured JSON	Pipeline with LLM key	playbook.steps phases present	P0	AI	Semi	playbook_agent
TC-AI-002	Template fallback no key	Clear LLM keys, run pipeline	llm_provider=template, hit likely	P0	AI	Auto	golden offline
TC-AI-003	Citation allow-list	Generated playbook	citation_ids subset-of KB	P0	AI	Auto	playbook
TC-AI-004	Grounding score range	Any playbook	0-1 float	P0	AI	Auto	golden
TC-AI-005	Cross-provider fallback	Primary fails, secondary key set	eff provider changes, log fallback	P1	AI	Semi	llm_provider
TC-AI-006	JSON parse resilience	Fenced/trailing comma LLM output	parse_llm_json succeeds	P0	AI	Auto	unit parse
TC-AI-007	Investigator SSE	Stream investigate	tokens + done	P1	AI	Semi	ai_investigator
TC-AI-008	Prompt injection note	Note with "ignore system"	Delimiters / no tool exec	P0	Security	Auto	investigate_prompt_safety
TC-AI-009	RCA fallback	No LLM budget/key	fallback RCA + reason	P1	AI	Auto	test_rca
TC-RAG-001	Hybrid search	KB search hybrid	Results with scores	P0	AI	Auto	vector_rag
TC-RAG-002	BM25 fallback	Vector disabled path	BM25 still works	P1	AI	Auto	vector
TC-RAG-003	Golden retrieval pairs	Offline retrieval eval	Hit@k thresholds	P1	AI	Auto	retrieval
TC-GOLD-001	Golden IR offline suite	pytest test_golden_benchmark	Pass CI gates	P0	AI	Auto	golden-ci
TC-GOLD-002	Golden UI run	Admin Golden page Run	Metrics render	P1	UI	Manual	GoldenBenchmark

6. HiTL / Review

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-HITL-001	Critical forces review	Critical incident	hitl_required true	P0	Functional	Auto	hitl_gate
TC-HITL-002	Low grounding forces review	Low ground playbook	pending_review	P0	Functional	Auto	hitl
TC-HITL-003	Approve with comment	Reviewer approve + notes	status approved, audit entry	P0	Functional	Auto/e2e	review
TC-HITL-004	Reject without comment	Empty comment	Client/server validation error	P0	Functional	Manual	Review UI
TC-HITL-005	Double approve race	Concurrent approve	One 409, one success	P1	Functional	Auto	review claim
TC-HITL-006	Review queue filters	Filter severity/threat	List updates	P2	UI	Manual	ReviewQueue

7. Investigation Workspace

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-WS-001	Load incident	Open /incidents/:id	Case loads	P0	UI	Auto	workspace tests
TC-WS-002	404 incident	Bad id	Error state not infinite load	P0	UI	Manual	IncidentDetail
TC-WS-003	Timeline API	GET timeline	Events ordered	P0	API	Auto	workspace_views
TC-WS-004	Entity graph	Assets/Users tabs	Graph/entities	P1	UI	Auto	workspace
TC-WS-005	Notes CRUD	Create note	Persists, audit	P0	API	Auto	workspace_api
TC-WS-006	RCA generate	POST rca	Narrative or fallback	P1	AI	Auto	rca
TC-WS-007	Tab URL state	Change tab	?tab=updates	P2	UI	Manual	WorkspaceTabs
TC-WS-008	Similar cases	GET similar	List or disabled reason	P2	API	Auto	similar

8. Dashboard / Analytics / Hunt

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-DASH-001	Live KPIs without demo flag	Open Dashboard, flag unset	Real Mongo counts; no DEMO banner	P0	UI	Manual	Dashboard
TC-DASH-002	Empty tenant zeros	Fresh DB	Zeros/empty charts, not fake 65 incidents	P0	UI	Manual	Dashboard
TC-DASH-003	Atomic load	Network throttle	KPIs+table paint together	P1	Performance	Manual	Dashboard
TC-DASH-004	KPI fields complete	GET /kpis	high/medium/events/iocs/top_techniques present	P0	API	Auto	analytics_service
TC-DASH-005	Demo flag banner	Set REACT_APP_DASHBOARD_DEMO_FALLBACK=true empty DB	DEMO DATA banner	P1	UI	Manual	Dashboard
TC-AN-001	Analytics window	Change 7/30 days	Charts refresh	P1	UI	Manual/e2e	Analytics
TC-AN-002	Analytics API error	Stop backend mid-page	Error message (not infinite load)	P1	UI	Manual	Analytics
TC-HUNT-001	NL hunt PowerShell	Query "suspicious PowerShell"	Results scored	P0	Functional	Auto	hunting
TC-HUNT-002	Behavior hotspots	Open Hunt	Hotspot cards if signals	P1	Functional	Auto	behavior

9. Compliance / Audit / Settings

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-CMP-001	Compliance status	GET /compliance/status	score, frameworks, domains	P0	API	Auto	compliance_score
TC-CMP-002	OIDC gap production	ENV=prod no OIDC	IAM-03 in gaps	P1	Functional	Auto	compliance_score

TC-CMP-003	Evidence pack download	UI button	JSON file	P1	UI	Manual	Compliance
TC-CMP-004	Executive export	GET executive-export	markdown + score	P1	API	Auto	executive_export
TC-AUD-001	Audit list normalize	Approve incident -> Audit page	analyst, incident_id, comment mapped	P0	Functional	Manual/Auto	audit
TC-AUD-002	Hash integrity	GET /audit/integrity	status ok/partial/legacy	P1	Security	Auto	audit_intelligence
TC-AUD-003	Summary narrative	GET /audit/summary	bullets + counts	P1	Functional	Auto	audit
TC-SET-001	Save LLM provider	Change provider+model, Save	Persists; toast shows pair	P0	UI	Manual	Settings
TC-SET-002	Invalid model soft warn	Custom model id	Warning not hard block	P1	UI	Manual	Settings
TC-SET-003	LLM catalog API	GET /settings/llm-catalog	free/paid lists	P1	API	Auto	executive_export_routes
TC-SET-004	Test LLM	Admin test connection	ok or structured error	P2	Integration	Manual	Settings
TC-SET-005	Clear TI secrets	Confirm clear	has_* false, mock TI	P1	Security	Manual	Settings

10. API / Modular / Ops

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-API-001	/api vs /api/v1 parity	Same path both prefixes	Same shape	P0	API	Auto	modular_api_v1
TC-API-002	OpenAPI drift	export --check	Match docs/openapi.json	P0	API	Auto	openapi-ci
TC-API-003	Health / ready	GET health/ready	mongo status	P0	Ops	Auto	smoke
TC-API-004	Metrics auth	GET metrics without admin	401/403	P1	Security	Auto	ops

TC-OPS-001	Multi-replica worker flag	ACTIRA_JOB_WORKER=0	No double process	P1	Ops	Auto	ha_multi_replica
TC-OPS-002	Retention purge dry	Ops retention path	Policy applied	P2	Ops	Auto	wave3

11. Security Suite

ID	Title	Expected	Priority	Automation
TC-SEC-001	No secrets in public settings	has_* only	P0	Auto
TC-SEC-002	Path traversal upload	Rejected	P0	Auto
TC-SEC-003	XSS in note title	Escaped in UI	P1	Manual
TC-SEC-004	CSRF cookie SameSite	Configured per CORS	P1	Manual
TC-SEC-005	Bandit / pip-audit CI	Green	P1	Auto CI
TC-SEC-006	Password policy	<12 rejected	P0	Auto

12. UI / E2E Smoke Matrix

ID	Flow	Expected	Automation
TC-E2E-001	Login -> Dashboard	KPIs load	Playwright smoke
TC-E2E-002	Upload sample -> job	Completes	workflow
TC-E2E-003	Open incident -> workspace tabs	Tabs switch	Manual (expand e2e)
TC-E2E-004	Review approve	Queue updates	smoke/workflow
TC-E2E-005	Theme toggle	Dark/light	theme-visual
TC-E2E-006	Logout	Login page	smoke
TC-E2E-007	Settings admin only	Analyst 403/redirect	smoke

Known gap: Align testids (dash-ingest-cta, incidents-filter-severity, kb-page) - track as P1.

13. Performance (manual / harness)

ID	Title	Expected	Priority
TC-PERF-001	Dashboard first paint	KPIs+table atomic; <3s lab	P1
TC-PERF-002	KPI cache	Second /kpis faster (cache hit)	P2
TC-PERF-003	Benchmarks smoke	benchmarks/run_benchmarks.py	P2
TC-PERF-004	10 concurrent uploads	No crash; jobs complete	P2

14. Execution Commands (for report appendix)

```
# Unit / backend (lab)
cd backend
python -m pytest tests -q --tb=line

# Golden offline
python -m pytest tests/test_golden_benchmark.py -q

# Wave C / resilience
python -m pytest tests/test_compliance_score.py tests/test_audit_intelligence.py
tests/test_llm_fallback_catalog.py tests/test_executive_export.py -q

# Frontend e2e (stack up)
cd frontend
npx playwright test e2e/smoke.spec.js
```

15. Formal run summary (2026-07-26)

Command (repo root):

```
python -m pytest backend/tests/test_golden_benchmark.py \
  backend/tests/test_compliance_score.py \
  backend/tests/test_audit_intelligence.py \
  backend/tests/test_llm_fallback_catalog.py \
  backend/tests/test_executive_export.py \
  backend/tests/test_rbac_matrix.py \
  backend/tests/test_hardening.py -q
```

Suite	Total	Pass	Fail	Blocked	Date	Notes
Golden IR + Wave C + RBAC + Hardening (combined)	66	66	0	0	2026-07-26	Exit 0, ~18s
Golden IR only	-	Pass	0	0	2026-07-26	Thresholds met (F1 0.982, recall 0.930)

Compliance / audit / LLM catalog / exec export	-	Pass	0	0	2026-07-26	Included in 66
Security (RBAC + hardening)	-	Pass	0	0	2026-07-26	Included in 66
Playwright smoke	-	Not run	-	-	-	Requires live stack; run before viva if time
Manual P0 UI (Dashboard live, screenshots)	-	Partial	-	-	2026-07-26	Code honesty fixes landed; capture screenshots in assets/screenshots/

TC automation status (aggregate): automated TC groups covered by the suites above -> Pass. Manual/UI TC-IDs remain Not run until demo screenshot session.

Use this catalog as the Test Plan appendix in the project report. Re-run and update dates before final PDF if code changes.

Appendix B - API surface (detailed)

Source: docs/capstone/appendices/B_api_surface.md

Location: docs/capstone/appendices/B_api_surface.md

Source snapshot: curated from repository OpenAPI for submission (dual mount /api and /api/v1).

Total documented paths in source OpenAPI: 178

Mounts

Mount	Purpose
/api	Primary SPA and integrations
/api/v1	Versioned parity for modular clients

Selected endpoints (submission-facing)

Path	Methods
/api/analytics	GET
/api/analytics/retrieval-compare	GET
/api/attack/catalog	GET
/api/attack/catalog/{technique_id}	GET
/api/attack/matrix	GET
/api/audit	GET
/api/audit/integrity	GET
/api/audit/logs	GET
/api/audit/summary	GET
/api/audit/telemetry	POST
/api/auth/login	POST
/api/auth/logout	POST
/api/auth/me	GET
/api/auth/oidc/callback	GET
/api/auth/oidc/config	GET
/api/auth/oidc/login	GET
/api/auth/register	POST
/api/compliance/evidence-pack	GET
/api/compliance/executive-export	GET
/api/compliance/gaps	GET

/api/compliance/score	GET
/api/compliance/status	GET
/api/eval/golden-benchmark	GET POST
/api/health	GET
/api/hunt	GET
/api/hunt/behavior	GET
/api/hunt/suggestions	GET
/api/incidents	GET
/api/incidents/{incident_id}	GET
/api/incidents/{incident_id}/behavior	GET
/api/incidents/{incident_id}/citations	GET
/api/incidents/{incident_id}/investigate	POST
/api/incidents/{incident_id}/investigate/stream	POST
/api/incidents/{incident_id}/investigations	GET
/api/incidents/{incident_id}/similar	GET
/api/incidents/{incident_id}/workspace	GET
/api/incidents/{incident_id}/workspace/entity-graph	GET
/api/incidents/{incident_id}/workspace/notes	GET POST
/api/incidents/{incident_id}/workspace/notes/{note_id}	DELETE PATCH
/api/incidents/{incident_id}/workspace/rca	GET POST
/api/incidents/{incident_id}/workspace/timeline	GET
/api/kb/custom	GET
/api/kb/custom/{doc_id}	DELETE
/api/kb/ingest	POST
/api/kb/lora/status	GET
/api/kb/lora/train	POST
/api/kb/reindex	POST
/api/kb/retrieval-eval	GET
/api/kb/search	GET
/api/kb/vector-status	GET
/api/kb/{doc_id}	GET
/api/kpis	GET

/api/logs/ingest	POST
/api/logs/ingest/raw	POST
/api/logs/jobs	GET
/api/logs/jobs/{job_id}	GET
/api/logs/jobs/{job_id}/events	GET
/api/logs/jobs/{job_id}/resume	POST
/api/logs/upload	POST
/api/logs/upload-batch	POST
/api/ready	GET
/api/review/queue	GET
/api/review/{incident_id}	POST
/api/settings	GET POST PUT
/api/settings/apply-profile	POST
/api/settings/clear-secrets	POST
/api/settings/email-outbox	GET
/api/settings/email-status	GET
/api/settings/llm-catalog	GET
/api/settings/profiles	GET
/api/settings/reset	POST
/api/settings/slack-status	GET
/api/settings/test-email	POST
/api/settings/test-llm	POST
/api/settings/test-slack	POST
/api/v1/analytics	GET
/api/v1/analytics/retrieval-compare	GET
/api/v1/attack/catalog	GET
/api/v1/attack/catalog/{technique_id}	GET
/api/v1/attack/matrix	GET
/api/v1/audit	GET
/api/v1/audit/integrity	GET
/api/v1/audit/logs	GET
/api/v1/audit/summary	GET
/api/v1/audit/telemetry	POST
/api/v1/auth/login	POST
/api/v1/auth/logout	POST
/api/v1/auth/me	GET

/api/v1/auth/oidc/callback	GET
/api/v1/auth/oidc/config	GET
/api/v1/auth/oidc/login	GET
/api/v1/auth/register	POST
/api/v1/compliance/evidence-pack	GET
/api/v1/compliance/executive-export	GET
/api/v1/compliance/gaps	GET
/api/v1/compliance/score	GET
/api/v1/compliance/status	GET
/api/v1/eval/golden-benchmark	GET POST
/api/v1/health	GET
/api/v1/hunt	GET
...	(+54 more matching paths in full OpenAPI)

Capability groups

Group	Examples
Auth	login, logout, me, register, OIDC scaffold
Ingest	logs/upload, jobs, batch
Incidents	list, detail, investigate stream
Workspace	timeline, graph, notes, RCA
Review / HiTL	queue, approve/reject
Hunt	NL hunt, behavior
Analytics / KPIs	dashboard metrics
Settings / LLM	catalog, vault, test-llm
Compliance	score, gaps, evidence, executive-export
Audit	list, integrity, summary
KB / RAG	search, ingest, vector-status
Eval	golden-benchmark
ATT&CK	catalog, matrix
Ops	health, ready

Notes for evaluators

- Cookie session auth applies to most routes; RBAC enforced on mutate/admin paths.
- This appendix is the submission-facing surface list kept inside the capstone pack.

- Dual /api and /api/v1 prefixes share handlers for modular clients.

Appendix C - Sample outputs

Source: docs/capstone/appendices/C_sample_outputs.md

Location: docs/capstone/appendices/C_sample_outputs.md

Machine-readable twin: C_sample_g001.json

Offline template-playbook run for golden case g001 (brute-force SSH). No live LLM or TI keys required.

C.1 Input log (excerpt)

```
Jan 12 10:00:01 web01 sshd[1023]: Failed password for root from 185.220.101.45 port 45322 ssh2
Jan 12 10:00:02 web01 sshd[1024]: Failed password for admin from 185.220.101.45 port 45325 ssh2
Jan 12 10:00:03 web01 sshd[1025]: authentication failure for invalid user oracle from 185.220.101.45
```

C.2 Expected labels (golden)

Field	Value
IoCs	ip:185.220.101.45
Techniques	T1110 (Brute Force)
Playbook phases	containment, eradication, recovery, lessons_learned
Min grounding	0.5

C.3 Offline prediction (template path)

Field	Value
IoCs	ip:185.220.101.45
Techniques	T1110
Phases	containment, eradication, recovery, lessons_learned
Grounding score	1.0
Severity	medium
HiTL required	false (example; critical/low-grounding cases force review)
LLM provider	template

Playbook steps (excerpt)

#	Phase	Action (summary)	Citations
1	containment	Isolate hosts; preserve volatile evidence	NIST-800-61-4.3
2	containment	Block malicious IoCs at perimeter/endpoint	T1110, PB-BRUTEFORCE
3	eradication	Remove artifacts; disable compromised accounts	T1110
4	recovery	Restore, rotate credentials, validate integrity	T1110

C.4 How to reproduce

```
# From repository root (lab)
python -c "from pathlib import Path; from backend.golden_eval import run_offline_case,
load_golden_dataset; c=load_golden_dataset(Path('backend/tests/golden/dataset.json'))[0];
print(run_offline_case(c['log'], force_template_playbook=True))"

# Full golden CI gate
python -m pytest backend/tests/test_golden_benchmark.py -q
```

C.5 Screenshots / figures

Place demo screenshots in:

- docs/capstone/assets/screenshots/
- Architecture exports in docs/capstone/assets/figures/

See docs/capstone/assets/screenshots/README.md.

Appendix D - Configuration

Source: docs/capstone/appendices/D_configuration.md

Location: docs/capstone/appendices/D_configuration.md

Do not commit real secrets. Values below are templates only.

D.1 Config files

File	Purpose
backend/.env	Local secrets & bootstrap (never commit)
backend/.env.example	Documented template in product repo
frontend/.env	REACT_APP_BACKEND_URL
Admin -> Settings UI	Runtime ops + encrypted vault

Secret resolution: Mongo settings (decrypted) -> process environment / .env.

D.2 Infrastructure (required)

Variable	Example	Notes
MONGO_URL	mongodb://localhost:27017	Compose: mongodb://mongodb:27017
DB_NAME	soc_console	Lab may use test DB names
CORS_ORIGINS	http://localhost:3000	Exact browser origins
JWT_SECRET	>=32 random chars	Weak refused when ENV not lab
ENV	dev / test / production	Affects seed, JWT checks

D.3 Auth & session

Variable	Notes
SESSION_TIMEOUT_HOURS	JWT lifetime
FAILED_LOGIN_LOCKOUT	Lock after N failures
SEED_DEMO_USERS	Lab only dual-gate
ALLOW_PUBLIC_REGISTER	Lab default; disabled in prod/OIDC
OIDC_*	Optional SSO scaffold (JWKS hardening still roadmap)

D.4 LLM (optional for peak quality)

Variable	Notes				
LLM_PROVIDER	anthropic \	openai \	gemini \	groq \	...
LLM_MODEL	Provider model id				
LLM_TEMPERATURE	e.g. 0.35				
ANTHROPIC_API_KEY / OPENAI_API_KEY / GEMINI_API_KEY / GROQ_API_KEY	Or Settings vault				
Cross-provider fallback	Configured via Settings / catalog				

Without keys, pipeline uses template playbooks (golden CI path).

D.5 Threat intelligence

Empty keys -> mock enrichment.

FORCE MOCK_TI=true forces mocks (CI).

Optional keys (vault or env): ABUSEIPDB_API_KEY, VIRUSTOTAL_API_KEY, GREYNOISE_API_KEY, THREATFOX_API_KEY, OTX_API_KEY, SHODAN_API_KEY, ...

D.6 Pipeline / HiTL

Variable	Meaning
GROUNDING_THRESHOLD	Below -> HiTL
HITL_SEVERITY_MIN	At/above severity -> always HiTL
AUTO_APPROVE_GROUNDING_MIN	Never bypasses severity gate
CORRELATION_WINDOW_MINUTES	Correlation window

D.7 Frontend honesty

Variable	Meaning
REACT_APP_BACKEND_URL	API base
REACT_APP_DASHBOARD_DEMO_FALLBACK	Omit / false for live KPIs; set true only for empty-DB demo fill

D.8 Minimal lab .env skeleton (sanitized)

```
ENV=dev
MONGO_URL=mongodb://localhost:27017
DB_NAME=soc_console
JWT_SECRET=replace-with-32-plus-char-random-string
CORS_ORIGINS=http://localhost:3000
FORCE MOCK_TI=true
# LLM_* and TI keys optional
```

```
# frontend/.env
REACT_APP_BACKEND_URL=http://localhost:8001
# REACT_APP_DASHBOARD_DEMO_FALLBACK not set = live data
```

Appendix E - Team roles

Source: docs/capstone/appendices/E_team_roles.md

Location: docs/capstone/appendices/E_team_roles.md

Source of names: product Login page team strip (Group 1).

E.1 Project identity

Field	Value
Project title	Agentic Cybersecurity Threat Intelligence & Incident Response Advisor (ACTIRA)
Capstone	Final Capstone Project
Program	Advanced Certification Programme in Agentic and Generative AI
Product codename	ACTIRA
Team	Group 1
Report date	27 July 2026

E.2 Team members (Group 1)

#	Name
1	Abhishek Patre
2	Aditya Sharma
3	Barshan Mukhar Das
4	Gaurav Eary
5	Nishant Ramesh Rao Patil
6	Prajwal B R
7	Praveen S N
8	Sarvesh Sood
9	Sindhu Subramanya
10	Vesalapu Satya Venkata Rupa

Evaluation focus is product capability (architecture, pipeline, HiTL, evaluation metrics, deliverables) - not individual workstream ownership lists.

E.3 Mentor / evaluator

Field	Value
Mentor name	Not assigned in repository - fill on the printed declaration / institute portal if TalentSprint or IISc track assigns a named mentor
Institute / track	Advanced Certification Programme in Agentic and Generative AI (TalentSprint / IISc track)
Evaluation board date	Per institute schedule (not fixed in-repo)
Signatures	Signature block in §E.5 is intentionally blank for wet-ink / portal upload - not a software defect

E.4 Product workstreams covered in this pack

Workstream	Artifacts in this pack / repo
Pipeline / parsers / IoC	Backend parsers, golden cases
RAG / playbooks / HiTL	Hybrid LanceDB RAG, playbook agent, review queue
Frontend workspace / dashboard	React SPA, live KPIs, investigation workspace
Security / RBAC / vault	Auth, hardening tests, Settings vault
Compliance / audit Wave C	Score, integrity chain, executive export
Testing / golden CI	appendices/A_test_case_catalog.md, pytest golden suite
Report / PPT / demo	PROJECT_REPORT.md, presentation/, demo video pack

E.5 Declaration

We declare that this Final Capstone Project work is our own (with documented use of open-source libraries and APIs), that claims match the board review and evaluation evidence in this pack, and that ACTIRA is presented as an advisory pilot product-not a certified SIEM/XDR replacement.

Name	Signature	Date
------	-----------	------

Appendix F - Glossary

Source: docs/capstone/appendices/F_glossary.md

Location: docs/capstone/appendices/F_glossary.md

Term	Definition
ACTIRA	Agentic Cybersecurity Threat Intelligence & Incident Response Advisor
Alignment score	Compliance readiness metric; not formal certification (ISO/SOC2)
ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge
BM25	Lexical ranking function used in hybrid RAG
CES	Common Event Schema - normalized event records after parse
Grounding	Score (0-1) of playbook support from retrieved citations
HiTL	Human-in-the-Loop - mandatory review gate for high-risk cases
IoC	Indicator of Compromise (IP, domain, URL, hash, ...)
LanceDB	Vector store used for hybrid retrieval (design choice vs Chroma)
Modular monolith	Single deployable backend with clear module boundaries
Mock TI	Deterministic enrichment when TI API keys are absent
NIST SP 800-61	Computer security incident handling guide (phase structure)
Playbook	Structured IR response steps with phases and citations
RAG	Retrieval-Augmented Generation
RCA	Root cause analysis narrative
RRF	Reciprocal Rank Fusion - combines BM25 and dense rankings
SOAR	Security Orchestration, Automation and Response (execution not unsupervised in ACTIRA)
SOC	Security Operations Center
Template playbook	Offline / no-LLM fallback IR structure used by golden CI
TI	Threat intelligence
Vault	Encrypted storage for API keys in Settings
Wave C	Product wave adding compliance score, audit intelligence, executive export